

EXAMEN DE SEGURIDAD EN EL DISEÑO DE SOFTWARE

PRUEBA FINAL DE LA ASIGNATURA

Nombre y apellidos: Juan Felipe Vinales Grupo: 19 Fecha: 30/6/2026

DNI: 78 500742C

1. ¿Qué es el principio de mínimo privilegio y por qué es importante en el diseño de software? (0,5 puntos)

El principio de mínimo privilegio consiste en darle a cada usuario o programa solo los permisos que necesita para hacer su tarea, y ninguno más. Así hay más seguridad.

2. Explica qué es una inyección SQL, cómo puede explotarse y qué medidas de diseño se deben aplicar para prevenirla. (2 puntos)

Una inyección SQL es un ataque en el que alguien mete código SQL malicioso en la web para acceder a la base de datos y robar información. Para prevenirla hay que validar bien lo que escribe el usuario en los formularios.

3. ¿Qué diferencia hay entre autenticación y autorización? (0,5 puntos)

La autenticación es comprobar quién eres, por ejemplo con usuario y contraseña. La autorización es ver qué cosas puedes hacer una vez que ya has entrado.

4. ¿Qué es el modelado de amenazas (threat modeling) y en qué fase del desarrollo debe realizarse? (1 punto)

El modelado de amenazas es analizar las posibles amenazas que puede tener un sistema para poder protegerlo mejor y poner medidas contra ellas.

5. Describe qué es la defensa en profundidad (defense in depth) como estrategia de seguridad y pon al menos tres ejemplos de capas que se pueden implementar en una aplicación web. (2 puntos)

La defensa en profundidad es poner varias medidas de seguridad distintas para estar más protegido, en vez de depender de una sola. Por ejemplo, un cortafuegos y usar contraseñas.

6. ¿Qué es el OWASP Top 10 y para qué sirve en el contexto del diseño seguro? (1 punto)

El OWASP Top 10 es una lista con los fallos de seguridad más comunes que suele haber en las páginas web.

7. Explica qué es un ataque de tipo Cross-Site Scripting (XSS), cuál es su impacto potencial y qué técnicas de diseño y desarrollo se deben emplear para mitigarlo. (2 puntos)

El Cross-Site Scripting (XSS) es cuando un atacante mete código JavaScript en una web para robar datos de los usuarios que la visitan. Para evitarlo hay que validar y filtrar lo que se introduce en la página.

8. ¿Qué es el cifrado en tránsito y en reposo, y por qué ambos son necesarios? (1 punto)

El cifrado en tránsito protege los datos cuando viajan por la red y el cifrado en reposo los protege cuando están guardados en el sistema. Los dos hacen falta para que la información esté segura.